

Smart Contract Assessment *M0*

HALBORN

Prepared by:  **HALBORN**

Last Updated 05/18/2026

Date of Engagement: April 29th, 2026 - April 30th, 2026

Summary

100% ⓘ OF ALL REPORTED FINDINGS HAVE BEEN ADDRESSED

ALL FINDINGS	CRITICAL	HIGH	MEDIUM	LOW	INFORMATIONAL
9	0	0	0	3	6

TABLE OF CONTENTS

1. Introduction
2. Assessment summary
3. Test approach and methodology
4. Risk methodology
5. Scope
6. Assessment summary & findings overview
7. Findings & Tech Details
 - 7.1 Forced_transfer_manager has unconstrained power to redirect any token balance with no on-chain safeguards
 - 7.2 Irreversible one-step sac admin transfer without two-step confirmation can permanently destroy sac control
 - 7.3 Off-path supply reconciliation treats all destroyed tokens as principal-like debits
 - 7.4 Taylor series rate cap exceeds documented accuracy range, allowing systematic yield underpayment at high rates
 - 7.5 Missing pausable guard on set_rate allows interest rate manipulation during emergency pause
 - 7.6 Missing ttl extension in constructor leaves instance storage with minimum ttl at deployment
 - 7.7 Direct sac set_authorized calls in block/unblock operations panic on accounts without trustlines
 - 7.8 Sac mint operations lack destination authorization preflight check
 - 7.9 Missing migration handler for storage schema changes after contract upgrade

1. Introduction

M0

stellar-minter-gateway

2. Assessment Summary

M0

Introduce at least one on-chain constraint on `force_transfer`, such as a pre-approved compliance destination registry or a `to != caller` check, to reduce the blast radius of a compromised `forced_transfer_manager` key.

Introduce a two-step acceptance flow for SAC admin transfers to prevent irreversible loss of token control from a single mistaken or malicious transaction.

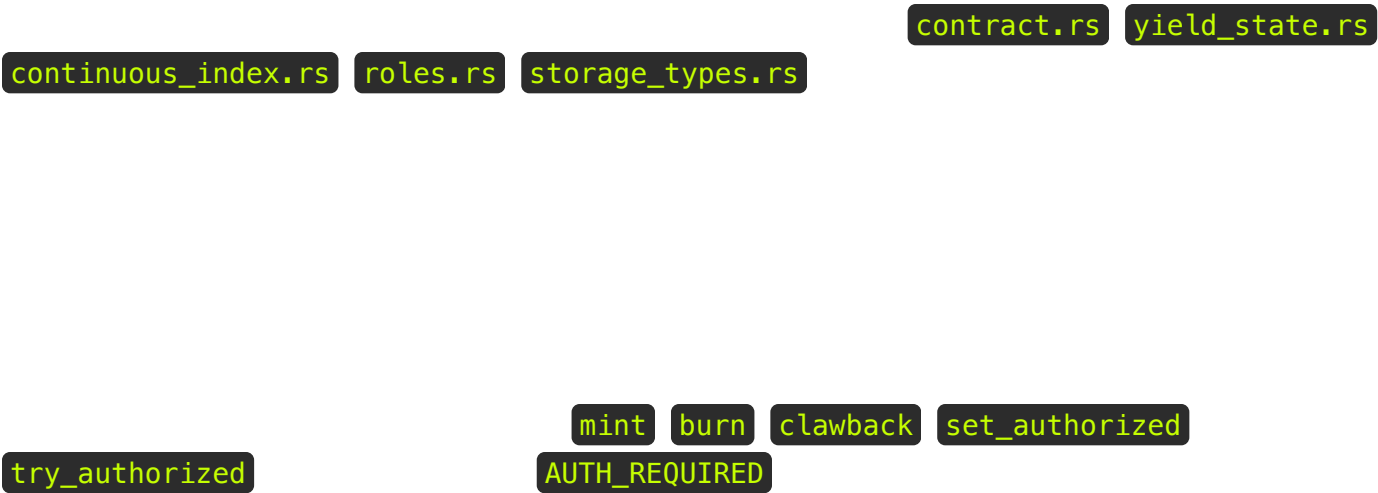
Replace `reconcile_burn` with an explicit-split entrypoint that accepts principal-origin and yield-origin amounts separately, enforcing correct accumulator attribution on-chain.

Lower the `set_interest_rate` cap from 10,000 bps to 2,000 bps to align the enforced maximum with the documented accuracy range of the Taylor series approximation.

Add `pausable::when_not_paused` to `set_rate` to prevent interest rate manipulation during an emergency pause.

Adopt defensive safeguards at key contract lifecycle boundaries (initialization, authorization enforcement, and upgrade preparation) to prevent opaque panics, transaction aborts, and operational gaps on future upgrades.

3. Test Approach And Methodology



METRICS:

EXPLOITABILITY METRIC (M_E)	METRIC VALUE	NUMERICAL VALUE
Attack Origin (AO)	Arbitrary (AO:A) Specific (AO:S)	1 0.2
Attack Cost (AC)	Low (AC:L) Medium (AC:M) High (AC:H)	1 0.67 0.33
Attack Complexity (AX)	Low (AX:L) Medium (AX:M) High (AX:H)	1 0.67 0.33

E

$E = \prod m_e$

4.2 IMPACT

CONFIDENTIALITY (C):

INTEGRITY (I):

AVAILABILITY (A):

DEPOSIT (D):

YIELD (Y):

METRICS:

IMPACT METRIC (M_I)	METRIC VALUE	NUMERICAL VALUE
Confidentiality (C)	None (C:N)	0
	Low (C:L)	0.25
	Medium (C:M)	0.5
	High (C:H)	0.75
	Critical (C:C)	1
Integrity (I)	None (I:N)	0
	Low (I:L)	0.25
	Medium (I:M)	0.5
	High (I:H)	0.75
	Critical (I:C)	1
Availability (A)	None (A:N)	0
	Low (A:L)	0.25
	Medium (A:M)	0.5
	High (A:H)	0.75
	Critical (A:C)	1
Deposit (D)	None (D:N)	0
	Low (D:L)	0.25
	Medium (D:M)	0.5
	High (D:H)	0.75
	Critical (D:C)	1
Yield (Y)	None (Y:N)	0
	Low (Y:L)	0.25
	Medium (Y:M)	0.5
	High (Y:H)	0.75
	Critical (Y:C)	1

I

$$I = \max(m_I) + \frac{\sum m_I - \max(m_I)}{4}$$

METRICS:

SEVERITY COEFFICIENT (<i>C</i>)	COEFFICIENT VALUE	NUMERICAL VALUE
Reversibility (<i>r</i>)	None (R:N) Partial (R:P) Full (R:F)	1 0.5 0.25

SEVERITY COEFFICIENT (<i>C</i>)	COEFFICIENT VALUE	NUMERICAL VALUE
Scope (<i>s</i>)	Changed (S:C) Unchanged (S:U)	1.25 1

$$C$$

$$C = rs$$

$$S$$

$$S = min(10, EIC * 10)$$

SEVERITY	SCORE VALUE RANGE
Critical	9 - 10
High	7 - 8.9
Medium	4.5 - 6.9
Low	2 - 4.4
Informational	0 - 1.9

5. SCOPE

FILE



- /stellar-minter-gateway-e14b4ab0697434622bea68ae41781ed9e49d397c/contracts/mintergateway/src/admin.rs
- /stellar-minter-gateway-e14b4ab0697434622bea68ae41781ed9e49d397c/contracts/mintergateway/src/constants.rs
- /stellar-minter-gateway-e14b4ab0697434622bea68ae41781ed9e49d397c/contracts/mintergateway/src/continuous_index.rs
- /stellar-minter-gateway-e14b4ab0697434622bea68ae41781ed9e49d397c/contracts/mintergateway/src/contract.rs
- /stellar-minter-gateway-e14b4ab0697434622bea68ae41781ed9e49d397c/contracts/mintergateway/src/errors.rs
- /stellar-minter-gateway-e14b4ab0697434622bea68ae41781ed9e49d397c/contracts/mintergateway/src/events.rs
- /stellar-minter-gateway-e14b4ab0697434622bea68ae41781ed9e49d397c/contracts/mintergateway/src/lib.rs
- /stellar-minter-gateway-e14b4ab0697434622bea68ae41781ed9e49d397c/contracts/mintergateway/src/roles.rs
- /stellar-minter-gateway-e14b4ab0697434622bea68ae41781ed9e49d397c/contracts/mintergateway/src/sac_token.rs
- /stellar-minter-gateway-e14b4ab0697434622bea68ae41781ed9e49d397c/contracts/mintergateway/src/storage_types.rs
- /stellar-minter-gateway-e14b4ab0697434622bea68ae41781ed9e49d397c/contracts/mintergateway/src/yield_state.rs

REMEDATION COMMIT ID:

<https://github.com/m0-foundation/stellar-minter-gateway/commit/3d800b6>

287a29e
<https://github.com/m0-foundation/stellar-minter-gateway/pull/64>
<https://github.com/m0-foundation/stellar-minter-gateway/commit/fd8891a>

Out-of-Scope:

6. ASSESSMENT SUMMARY & FINDINGS OVERVIEW

CRITICAL

HIGH

MEDIUM

LOW

INFORMATIONAL

SECURITY ANALYSIS	RISK LEVEL	REMEDIATION DATE
FORCED_TRANSFER_MANAGER HAS UNCONSTRAINED POWER TO REDIRECT ANY TOKEN BALANCE WITH NO ON-CHAIN SAFEGUARDS	LOW	RISK ACCEPTED - 05/09/2026
IRREVERSIBLE ONE-STEP SAC ADMIN TRANSFER WITHOUT TWO-STEP CONFIRMATION CAN PERMANENTLY DESTROY SAC CONTROL	LOW	RISK ACCEPTED - 05/09/2026
OFF-PATH SUPPLY RECONCILIATION TREATS ALL DESTROYED TOKENS AS PRINCIPAL-LIKE DEBITS	LOW	RISK ACCEPTED - 05/09/2026
TAYLOR SERIES RATE CAP EXCEEDS DOCUMENTED ACCURACY RANGE, ALLOWING SYSTEMATIC YIELD UNDERPAYMENT AT HIGH RATES	INFORMATIONAL	SOLVED - 05/06/2026
MISSING PAUSABLE GUARD ON SET_RATE ALLOWS INTEREST RATE MANIPULATION DURING EMERGENCY PAUSE	INFORMATIONAL	SOLVED - 05/11/2026
MISSING TTL EXTENSION IN CONSTRUCTOR LEAVES INSTANCE STORAGE WITH MINIMUM TTL AT DEPLOYMENT	INFORMATIONAL	SOLVED - 05/06/2026

SECURITY ANALYSIS	RISK LEVEL	REMEDIATION DATE
DIRECT SAC SET_AUTHORIZED CALLS IN BLOCK/UNBLOCK OPERATIONS PANIC ON ACCOUNTS WITHOUT TRUSTLINES	INFORMATIONAL	ACKNOWLEDGED - 05/09/2026
SAC MINT OPERATIONS LACK DESTINATION AUTHORIZATION PREFLIGHT CHECK	INFORMATIONAL	SOLVED - 05/06/2026

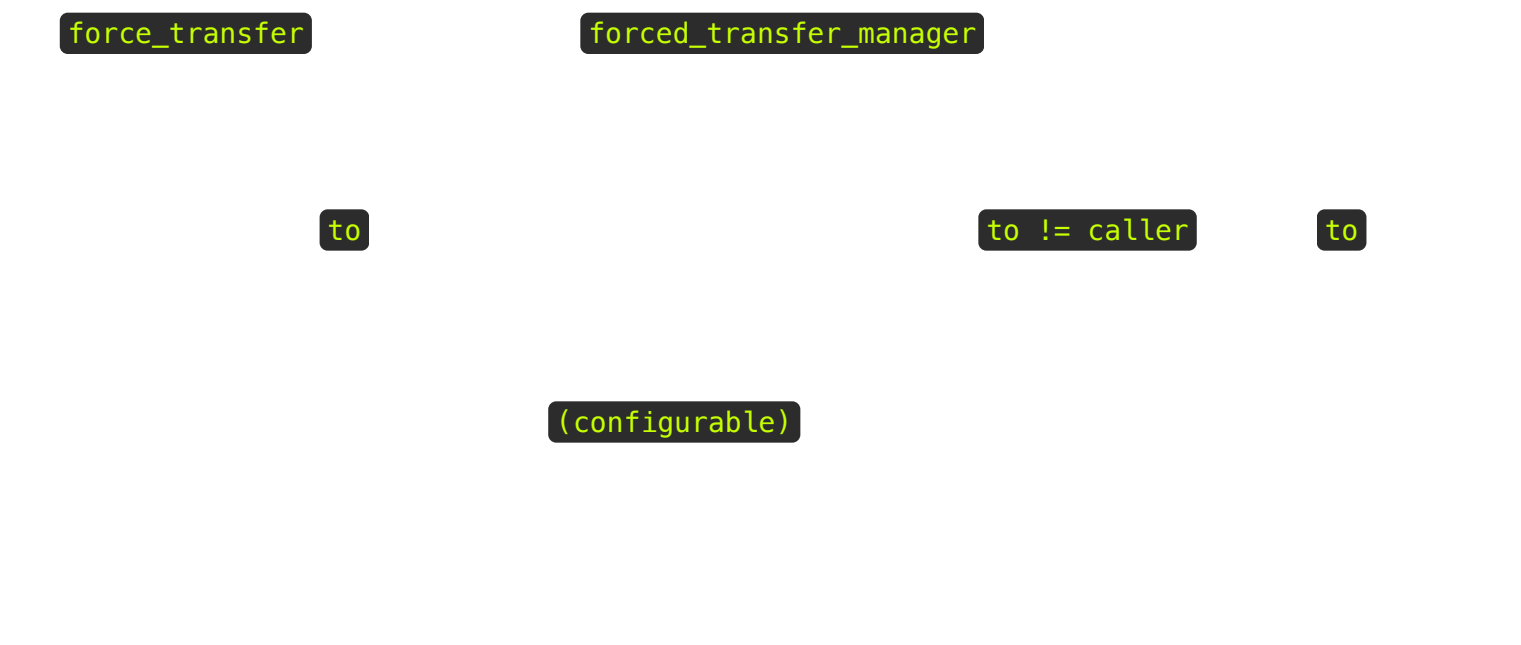
SECURITY ANALYSIS	RISK LEVEL	REMEDIATION DATE
MISSING MIGRATION HANDLER FOR STORAGE SCHEMA CHANGES AFTER CONTRACT UPGRADE	INFORMATIONAL	ACKNOWLEDGED - 05/09/2026

7. FINDINGS & TECH DETAILS

7.1 FORCED_TRANSFER_MANAGER HAS UNCONSTRAINED POWER TO REDIRECT ANY TOKEN BALANCE WITH NO ON-CHAIN SAFEGUARDS

// LOW

Description



Code Location

force_transfer contracts/mintergateway/src/contract.rs

Copy Code

```
460 | pub fn force_transfer(
461 |     e: Env, caller: Address, from: Address, to: Address, amount: i128,
462 | ) -> Result<(), MinterGatewayError> {
463 |     pausable::when_not_paused(&e);
464 |     check_positive_amount(amount)?;
465 |     require_role_holder(&caller, &read_forced_transfer_manager(&e))?;
466 |
467 |     let sac_client = token::StellarAssetClient::new(&e, &read_sac_token(&e));
468 |
469 |
470 |
471 |     emit_force_transfer(&e, from, to, amount);
472 |     Ok(())
473 | }
```

Impact

forced_transfer_manager

BVSS

Recommendation

forced_transfer_manager

DataKey::ComplianceWallet

to != caller

to == compliance_wallet

forced_transfer_manager

Remediation Comment

M0

forced_transfer_manager

force_transfer

forced_transfer_manager

7.2 IRREVERSIBLE ONE-STEP SAC ADMIN TRANSFER WITHOUT TWO-STEP CONFIRMATION CAN PERMANENTLY DESTROY SAC CONTROL

// LOW

Description

transfer_sac_admin

Code Location

transfer_sac_admin

contracts/mintergateway/src/contract.rs

 Copy Code

```
307 |     /// Transfers SAC admin role to another address. Admin only.
308 |     /// After this call the contract loses the ability to mint, burn,
309 |     /// clawback and authorize accounts on the SAC.
310 |     pub fn transfer_sac_admin(e: Env, new_sac_admin: Address) {
311 |         require_admin(&e);
312 |         extend_instance_ttl(&e);
313 |
314 |         let sac_addr = read_sac_token(&e);
315 |
316 |         emit_sac_admin_transferred(&e, new_sac_admin);
317 |
318 |     }
```


Impact

BVSS

Recommendation

PendingSacAdmin

set_admin

new_sac_admin

Remediation Comment

M0

transfer_sac_admin

7.3 OFF-PATH SUPPLY RECONCILIATION TREATS ALL DESTROYED TOKENS AS PRINCIPAL-LIKE DEBITS

// LOW

Description

total_supply

mint

claim_yield

total_principal

mint

burn

reconcile_burn(amount)

reconcile_burn

total_supply

burn

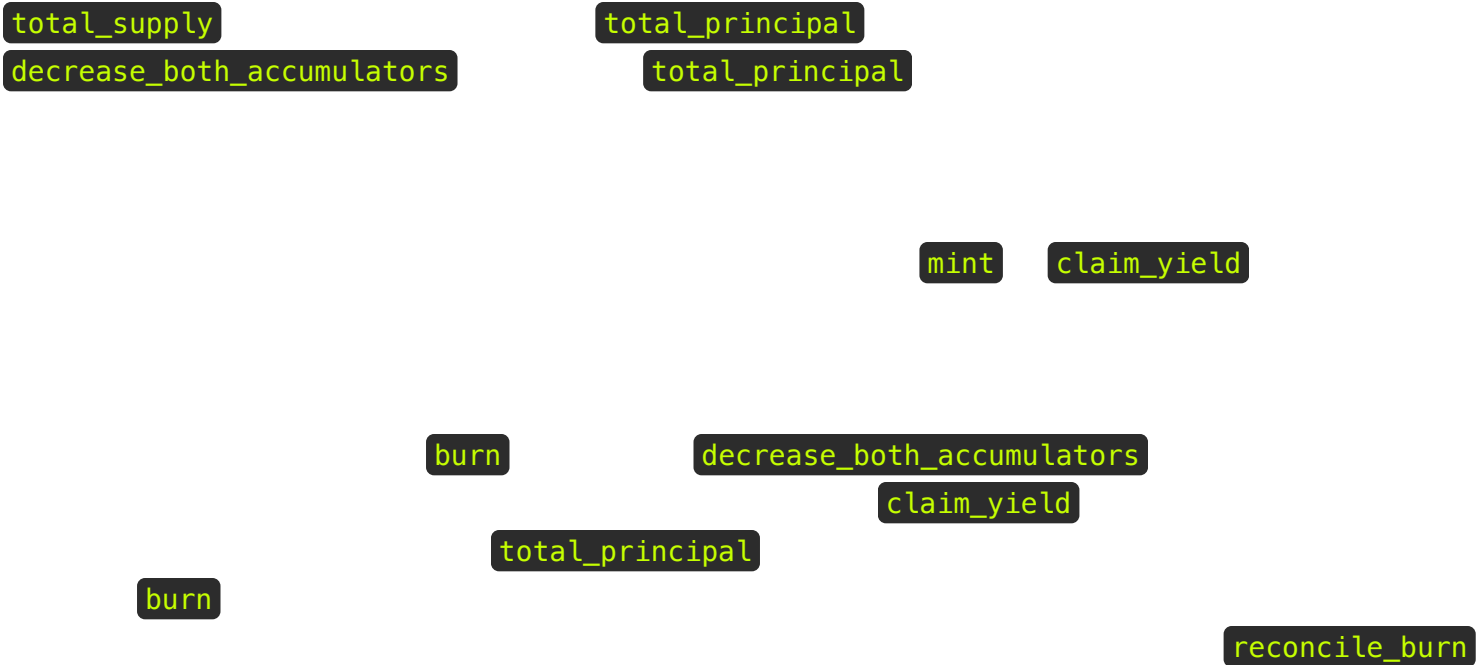
amount

decrease_both_accumulators(amount)

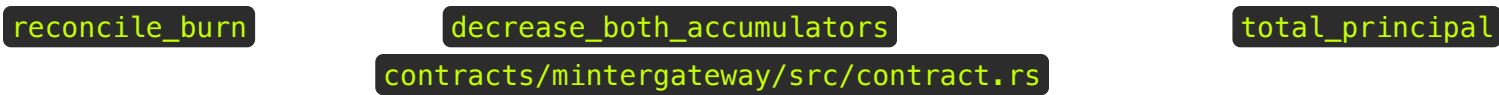
total_principal

mint

claim_yield



Code Location



Copy Code

```
402 | pub fn reconcile_burn(e: Env, amount: i128) -> Result<(), MinterGatewayError> {
403 |     // ...
404 |     update_index(&e);
405 |
406 |     if amount > get_total_supply(&e) {
407 |         return Err(MinterGatewayError::BurnExceedsSupply);
408 |     }
409 | }
```



Copy Code

```
529 | // Increase total_supply (but NOT total_principal - no compounding)
```

Impact



BVSS

Recommendation

amount

 Copy Code

```
pub fn reconcile_destroyed(
  e: Env,
  principal_nominal: i128,
  yield_nominal: i128,
) -> Result<(), MinterGatewayError> {
  //...
  let total = principal_nominal + yield_nominal;
  // validate total <= total_supply
  let pv_amount = principal_nominal * INDEX_SCALE / latest_index;
  state.total_principal -= pv_amount; // PV debit only for principal-origin tokens
  state.total_supply    -= total;    // single supply debit for the full destroyed amount
  //...
}
```

reconcile_supply_only

reconcile_burn

total_supply

total_principal

 Copy Code

```
pub fn reconcile_supply_only(e: Env, amount: i128) -> Result<(), MinterGatewayError> {
  // decrements total_supply only - no PV debit on total_principal
  //...
}
```


reconcile_burn

Remediation Comment

M0

reconcile_burn

total_principal

7.4 TAYLOR SERIES RATE CAP EXCEEDS DOCUMENTED ACCURACY RANGE, ALLOWING SYSTEMATIC YIELD UNDERPAYMENT AT HIGH RATES

// INFORMATIONAL

Description

e^x

continuous_index.rs:44

set_interest_rate

$x = 1.0$

$x = 1.0$

update_index

X	RATE × PERIOD	TAYLOR (5 TERMS)	TRUE E^X	ERROR	
0.20	20% × 1 yr (documented limit)	1.22140	1.22140	~0.00007%	
0.50	50% × 1 yr	1.64844	1.64872	~0.017%	
1.00	100% × 1 yr (contract max)	2.70833	2.71828	~0.37%	
2.00	100% × 2 yr (no forced update)	7.00000	7.38906	~5.26%	

Code Location

contracts/mintergateway/src/continuous_index.rs

Copy Code

45 | pub fn exponent(x: i128) -> i128 {

contracts/mintergateway/src/yield_state.rs

Copy Code

215 | pub fn set_interest_rate(env: &Env, rate_bps: u32) -> Result<(), MinterGatewayError> {

217 | return Err(MinterGatewayError::RateExceedsMax);
218 | }

}

Impact

update_index

BVSS

M0

MAX_RATE_BPS

10,000

set_interest_rate

exponent()

$x \leq 0.5$

Remediation Hash

7.5 MISSING PAUSABLE GUARD ON SET_RATE ALLOWS INTEREST RATE MANIPULATION DURING EMERGENCY PAUSE

// INFORMATIONAL

Description

pausable::when_not_paused(&e)

set_rate

set_rate

update_index()

set_interest_rate()

latest_index

rate_bps

last_update_timestamp

Code Location

set_rate

contracts/mintergateway/src/contract.rs

 Copy Code

```
432 | pub fn set_rate(e: Env, caller: Address, rate_bps: u32) -> Result<(), MinterGatewayError> {
433 |     // pausable::when_not_paused(&e) - missing
434 |     require_role_holder(&caller, &read_minter(&e))?;
435 |     extend_instance_ttl(&e);
436 |     // ...
437 |     update_index(&e);
438 |     set_interest_rate(&e, rate_bps)?;
439 | }
```

Impact


```
set_rate(minter, 10_000)
```

```
update_index()
```

```
claim_yield
```

```
set_rate(minter, 0)
```

BVSS

Recommendation

```
pausable::when_not_paused(&e)
```

```
set_rate
```

Remediation Comment

```
M0
```

```
when_not_paused()
```

Remediation Hash

7.6 MISSING TTL EXTENSION IN CONSTRUCTOR LEAVES INSTANCE STORAGE WITH MINIMUM TTL AT DEPLOYMENT

// INFORMATIONAL

Description

extend_instance_ttl

extend_instance_ttl

Code Location

__constructor

contracts/mintergateway/src/contract.rs

extend_instance_ttl

```
62 pub fn __constructor(e: Env, ...) -> Result<(), MinterGatewayError> {
63     if has_admin(&e) {
64         return Err(MinterGatewayError::AlreadyInitializedError);
65     }
66
67     write_sac_token(&e, &sac_token);
68     write_admin(&e, &admin);
69     write_minter(&e, &minter);
70     write_yield_recipient_manager(&e, &yield_recipient_manager);
71     write_yield_recipient(&e, &yield_recipient);
72     write_forced_transfer_manager(&e, &forced_transfer_manager);
73     insert_block_operator(&e, &block_operator);
74     insert_unblock_operator(&e, &unblock_operator);
75     write_pauser(&e, &pauser);
76
77     Ok(()) // extend_instance_ttl never called
```

 Copy Code

Impact

BVSS

Recommendation

Ok()

extend_instance_ttl(&e)

__constructor

Remediation Comment

M0

__constructor

extend_instance_ttl()

7.7 DIRECT SAC SET_AUTHORIZED CALLS IN BLOCK/UNBLOCK OPERATIONS PANIC ON ACCOUNTS WITHOUT TRUSTLINES

// INFORMATIONAL

Description

block_user unblock_user batch_block_users batch_unblock_users
try_ set_authorized

blocked() try_authorized

Code Location

block_user unblock_user contracts/mintergateway/src/contract.rs
try_)

Copy Code

```
225 | pub fn block_user(e: Env, user: Address, operator: Address) -> Result<(), MinterGatewayError> {
226 |     require_block_operator(&e, &operator)?;
227 |     extend_instance_ttl(&e);
228 |     let sac_addr = read_sac_token(&e);
230 |     emit_user_blocked(&e, &user);
231 |     Ok(())
232 | }
```

blocked() try_authorized

Copy Code

```
546 | pub fn blocked(e: Env, account: Address) -> bool {
547 |     extend_instance_ttl(&e);
548 |     let sac_addr = read_sac_token(&e);
550 |     Ok(Ok(authorized)) => !authorized,
551 |     _ => true,
552 | }
553 | }
```

Impact

InvokeError::Abort

BVSS

Recommendation

set_authorized

try_set_authorized

blocked()

```
1 | for user in users.iter() {  
2 |     // Skip accounts with no trustline; they cannot transact regardless  
3 |     if sac_client.try_set_authorized(&user, &false).is_ok() {  
4 |         emit_user_blocked(&e, &user);  
5 |     }  
6 | }
```

 Copy Code

Remediation Comment

M0

set_authorized

blocked()

7.8 SAC MINT OPERATIONS LACK DESTINATION AUTHORIZATION PREFLIGHT CHECK

// INFORMATIONAL

Description

AUTH_REQUIRED mint
claim_yield force_transfer mint StellarAssetClient::mint
InvokeError::Abort
blocked() try_authorized

BVSS

Recommendation

try_authorized
sac_client mint
MinterGatewayError::DestinationUnauthorized

Remediation Comment

M0
require_destination_trustline_authorized try_authorized
MinterGatewayError::NoTrustline
mint mint force_transfer

claim_yield

force_transfer

clawback

Remediation Hash

7.9 MISSING MIGRATION HANDLER FOR STORAGE SCHEMA CHANGES AFTER CONTRACT UPGRADE

// INFORMATIONAL

Description

upgrade()

update_current_contract_wasm()

migrate()

update_current_contract_wasm

upgrade(new_hash)

migrate()

migrate()

migrate()

YieldStateValue

DataKey

total_principal

total_supply

Code Location

upgrade()

contracts/mintergateway/src/contract.rs

 Copy Code

```
320 | /// Upgrades the contract WASM to a new version. Admin only.  
321 | /// The new WASM must already be uploaded to the ledger.
```

```
324 | pub fn upgrade(e: Env, new_wasm_hash: BytesN<32>) {  
325 |     let admin = require_admin(&e);  
326 |     extend_instance_ttl(&e);  
327 |     e.deployer()  
328 |         .update_current_contract_wasm(new_wasm_hash.clone());  
329 |     emit_upgraded(&e, admin, new_wasm_hash);  
330 | }
```

Impact

total_principal

total_supply

BVSS

Recommendation

migrate()

Remediation Comment

M0

migrate()

upgrade(new_hash)

migrate()

migrate()
